授权即密钥：面向多智能体委托执行的谓词门控协同 SM2 签名机制

【待填：作者与单位；若复赛要求匿名则删去】

写作指引：标题的两个备选：（1）当前标题；（2）“基于谓词门控协同 SM2 签名的智能体委托执行与支付授权”。标题里不要出现“门限 SM2”，因为本轮实现的是 $n = 2$ 的协同签名；也不要出现“首个”“全新协议”。

摘要

写作指引：摘要按“问题—方法—实现—结果—边界”五句话写。每个数字都必须来自实测，并能在第 7 节找到出处。“实现了”只能用于已勾选的交付项（见实施规划第 5 节）。

大模型智能体以委托方式代用户调用工具和发起支付时，授权检查通常集中在单一网关或授权服务器：一旦该组件的签名密钥或逻辑被攻破，任务边界、撤销和预算约束随之失效；而受提示注入影响的智能体也可能尝试越权执行。本文提出“授权即密钥”机制：把执行凭据的 SM2 签名密钥以两方协同方式分布于**授权域**与**执行域**，授权域仅在独立核验委托链、撤销状态与剩余预算等授权谓词成立后，才参与生成签名；最终输出是标准 SM2 签名，可由任何符合 GB/T 32918 的验签实现直接验证，并可同时作为网关执行凭据与支付意图批准。我们在已有的 OAuth 委托授权与国密持有者证明系统上实现了双域原型，密钥生成无需可信分发者，并给出向 t-of-n 访问结构推广的构造。在半诚实模型下，我们论证了任一单域被攻破都无法为未授权或已撤销的行动产生有效凭据。在多智能体协同采购场景中，【待填：X】类攻击均在预期位置被拒绝，且未产生业务效果；一次协同签名的中位耗时为【待填：Y】ms（$n = 100$），约为单方 SM2 签名的【待填：Z】倍。

关键词：协同签名；SM2；委托授权；智能体安全；OAuth；动态撤销

1 引言

写作指引：共 5 段。第 1 段讲一个具体例子，不讲技术名词；第 2 段讲两个风险；第 3 段讲现有标准和研究已经解决了什么、还缺什么；第 4 段讲本文思路（一句话主张）；最后列贡献。全篇只围绕两条主线：智能体越权，以及单点被攻破。预算、恢复、审计放到第 6 节作为支撑机制，不要在引言里展开。

场景。 用户委托一组智能体完成企业采购：统筹代理拆分任务，选品代理比价，执行代理下单付款。用户批准的是一个有边界的任务（例如“1000 元以内、指定供应商、本周有效”），而不是把账户交给智能体。

两个风险。 第一，智能体处理的报价、网页等外部内容可能含有恶意指令，使其提出超出任务边界的操作。第二，即使授权协议本身正确，负责“说可以”的组件——授权服务器（AS）或执行网关——也是单点：其签名密钥泄露或逻辑被篡改，所有约束都会失效。

现有方法与缺口。 OAuth 令牌交换 [1] 和发送者约束 [2] 能限制令牌被盗用，委托收窄与动态撤销可以在应用层实现，但这些检查最终仍由单一组件执行。门限签名能把一个签名能力分散到多方 [10, 11]，近期工作 KITA [12] 将其用于智能体的行动审批，由多个 LLM 评审者投票后释放签名份额。然而，现有审批类方案的签名方依据的是语义判断或静态策略，并不独立核验 OAuth 委托链和撤销状态，而且普遍采用非国密算法。【待填：C 在核对 KITA 原文后，补一句它在撤销/委托链方面的实际情况；不确定就写“未见讨论”】

本文思路。 我们让**授权本身成为密钥**：执行凭据的 SM2 私钥被拆分在两个独立信任域，授权域只有在亲自确认“此刻这一行动确实被授权”时才交出它那一半签名能力。因此，一个有效签名本身就证明了授权谓词在签名时成立，这个证明可以随请求携带，任何持有公钥的一方都能用标准 SM2 验签确认。

贡献。

1. **谓词门控的协同 SM2 签名。**我们提出一种把签名份额的释放条件与可验证授权谓词绑定的构造：授权域独立核验 AS 签名的委托链、撤销状态与剩余预算后，才参与两方 SM2 协同签名。产出的签名与普通 SM2 签名不可区分，密钥生成无需可信分发者（第 4）。
2. **与委托授权和支付的一致组合。**该签名作为执行凭据，在网关的接受事务内与实际订单、授权路径和预算逐项绑定；签名之后发生的撤销仍会被拒绝。【待填：若 B8 完成：它同时作为 x402 支付意图的批准】（第 4 and 6）。
3. **安全分析与实证。**我们定义了“执行授权不可伪造性”，并在半诚实模型下给出论证；在真实 PostgreSQL、真实 AS 签发链和独立下游服务上，验证了【待填：N】个正负用例，并测量了各阶段开销（第 5 and 7）。

> **写作指引：**贡献只写这三条，每条结尾都要指向对应章节。已有的 OAuth/AGPoP/预算/恢复能力在第 3、6 节作为“基础”介绍，不列为贡献。

2 背景与相关工作

> **写作指引：**每个小节先说别人解决了什么，再说和本文的区别。对别人的方案不确定的地方写“未确认”，不能因为没看到就写成“不支持”。

2.1 OAuth 委托与发送者约束

> **写作指引：**RFC 8693 令牌交换、RFC 9449 DPoP、RFC 9700 安全最佳实践。强调本文**不**声称首创发送者约束；本项目的 AGPoP 是参照 DPoP 思路的国密私有 profile，不与标准 DPoP 互通。

2.2 SM2 门限与协同签名

写作指引： SM2 签名 $s = (1+d)^{-1}(k+r) - r$ 中含有 $(1+d)^{-1}$，不能像 Schnorr 那样把份额线性相加，这是 SM2 门限化的难点。可按以下脉络写：两方协同签名[6]；无可信中心的门限方案[7]；基于同态加密与零知识证明、可识别中止的方案[8, 9]。说明本文采用其中最简洁的两方乘法分享结构，贡献**不在**签名算法本身，而在于份额释放条件与授权状态的绑定。

2.3 智能体的行动审批与门限签名

写作指引： 重点写 KITA[12]。KITA：提议者不持有份额，多个 LLM 评审者审查同一规范化授权对象，审查通过后签名服务释放份额，最终形成门限 BLS 签名，采用 DKG。在其安全论证中，审批通道没有被建模（可引用外部评审的这一观察，但要注明来源）。与本文的区别用下表说明。

表 1: 与相近方案的比较（“未确认”表示原文中未找到相关描述）

	单钥 SM2 批准	FROST 2-of-3 （本项目旧版）	KITA[12]	本文 双域共签
签名算法	SM2	Ed25519	门限 BLS	SM2（标准签名）
份额释放依据	—	静态策略	LLM 语义评审	**可验证授权谓词**
密钥初始化	单方生成	可信分发者	DKG	两方交互，无分发者
签名方核验委托链	否	否	【待填：核实】	**是**
签名方核验撤销	否	否	【待填：核实】	**是**
单方被攻破仍可签	是	否	否（$< t$）	否
国密算法	是	否	否	是
已实现规模	—	2-of-3	t-of-n	$n = 2$（推广已设计）

2.4 智能体支付

写作指引： x402 [13] 用 HTTP 402 承载支付要求与支付证明，V2 支持扩展与自定义 scheme。说明它解决的是“钱付对了”，而不是“这次付款被用户授权了”。若 B8 完成，再写本文如何让支付意图受共签约束；若未完成，本小节压缩为一段，并放进后续工作。

3 系统模型与威胁模型

3.1 参与方

写作指引： 按图 1逐一介绍：用户；统筹/选品/执行三代理（只能提出请求）；AS（统一签发各级 SM2 令牌，委托只能收窄）；授权域 P_{A}（与 AS 同一信任域，持份额 d_2）；执行网关与执行域 P_{E}（持份额 d_1）；授权与预算库（PostgreSQL，接受事务）；下游订单服务；回执与审计。

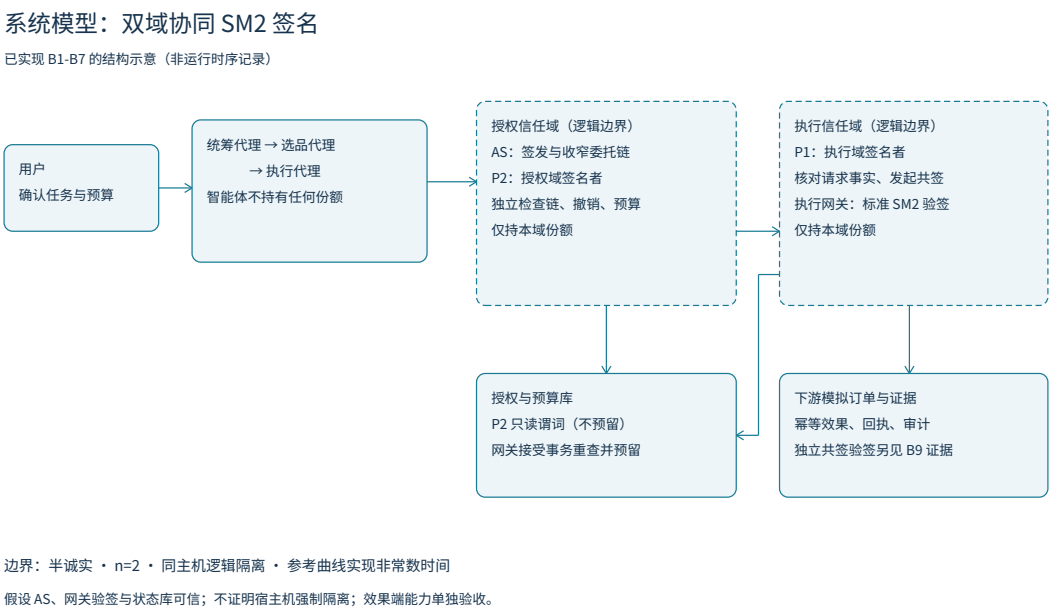


图 1: 系统模型与信任域划分。智能体不持有任何签名份额。

3.2 威胁模型

假设 1 (敌手能力)**.** 敌手可以：（1）完全控制所有智能体，包括让其提出任意请求、复制任意令牌；（2）攻破 P_{E}、P_{A} 中**至多一个**，获得其份额并以半诚实方式运行该域的协议；（3）观察和重放网络消息。

假设 2 (信任基础)**.** AS 的签名私钥与身份登记可信；下游订单服务的验签代码可信；SM2 满足 EUF-CMA 安全，SM3 可视为随机预言机。网关可以被攻破，但此时仅能获得执行域份额。

写作指引：必须写明不在范围内的情况：两域同时被攻破；恶意（非半诚实）参与方；侧信道（原型的标量乘不是常数时间）；同一主机、同一操作系统用户的部署（演示环境）。网关被攻破时的准确结论（不得扩大）：网关单方无法产生有效共签；下游订单服务独立以标准 SM2 验签、核对业务意图并拒绝同一批准跨操作重放，因此攻击者至多能把授权域在签名时已核准的那一笔执行一次；签名之后发生的撤销依赖网关接受事务拦截，网关失陷时在批准有效期内不受保护。不能写“网关被攻破后任何订单都无法产生”。

4 方案设计

4.1 基础：委托授权与持有者证明

写作指引：简要介绍已有系统：授权码 + PKCE 获得根令牌；两次令牌交换，每次由 AS 签发收窄后的子令牌（金额、工具、期限、次数、深度逐维比较）；执行代理每次调用附带 AG-Proof，用自己的 SM2 私钥签名，并以 SM3 绑定令牌与完整请求体；网关在接受事务内复核祖先撤销状态与共享预算。控制在一页以内，并注明这部分是“基础机制”。

4.2 授权行动对象

每一次需要批准的高风险操作都被规范化为行动对象 act，其中包含租户、任务、完整的根到叶授权路径、持有者与密钥标识、受众、工具及版本、业务幂等键、报价、商品条目、收货对象、金额（整数分）、参数摘要、策略版本、密钥纪元与过期时间【待填：若有：以及支付意图摘要】。签名消息为

$$M = \texttt{"AGENT-GUARD-COSM2-ACTION-V1\textbackslash n"} \,\|\, \mathrm{CanonicalJSON}(\mathsf{act}).$$

写作指引：说明域分离前缀的作用：防止与令牌、AG-Proof、旧版门限消息之间的跨协议重用。

4.3 两方协同 SM2 签名

记 SM2 曲线的阶为 n、基点为 G，用户标识固定为 1234567812345678。

密钥生成（无可信分发者）。 P_{E} 随机选取 $d_1 \in [1, n-1]$，发送 $T_1 = d_1^{-1}G$；P_{A} 随机选取 $d_2 \in [1, n-1]$，计算公钥 $P = d_2^{-1}T_1 - G$。此时 $(1+d)^{-1} \equiv d_1 d_2 \pmod{n}$，完整私钥 d 从不出现在任何一方。

签名。 见图 2。双方各自计算 $e = \mathrm{SM3}(Z_A \| M)$，$P_{\mathsf{A}}$ 不接受由 P_{E} 提供的 e。

1. P_{E}：$k_1 \xleftarrow{\$} [1, n-1]$，发送 $Q_1 = k_1 G$ 与 act。
2. P_{A}：**先检查授权谓词** $\Phi_{\mathsf{A}}(\mathsf{act})$（见第 4.4），不成立则拒绝并终止；校验 Q_1 合法；$k_2, k_3 \xleftarrow{\$} [1, n-1]$，$(x_1, \cdot) = k_3 Q_1 + k_2 G$，$r = (e + x_1) \bmod n$，$s_2 = d_2 k_3$，$s_3 = d_2(r + k_2)$；发送 (r, s_2, s_3) 后销毁 k_2, k_3。
3. P_{E}：$s = d_1 k_1 s_2 + d_1 s_3 - r \bmod n$；若 $s = 0$ 或 $s = n - r$ 则重新开始；用 P 做标准 SM2 验签，通过后输出 (r, s)，并销毁 k_1。

引理 1 (正确性)**.** 令 $k = k_1 k_3 + k_2$，则 $s = (1+d)^{-1}(k + r) - r \bmod n$，$(r, s)$ 是消息 M 在公钥 P 下的标准 SM2 签名。

Proof. x_1 是 kG 的横坐标；$s = d_1 d_2 (k_1 k_3 + k_2 + r) - r = (1+d)^{-1}(k + r) - r$。 □

4.4 授权谓词

$$\begin{aligned}\Phi_{\mathsf{A}}(\mathsf{act}, t) = \mathsf{ChainValid} \wedge \mathsf{PathMatch} \wedge \mathsf{InScope} \wedge \mathsf{PolicyMatch} \\ \wedge \mathsf{NotRevoked}(t) \wedge \mathsf{NotExpired}(t) \wedge \mathsf{BudgetOK}(t)\end{aligned}$$

写作指引：逐项解释，并对应到实现中的拒绝码（AUTHZ_PATH_MISMATCH、AUTHZ_SCOPE、AUTHZ_REVOKED、AUTHZ_EXPIRED、AUTHZ_OVER_BUDGET、AUTHZ_POLICY_MISMATCH）。执行域谓词 Φ_{E} 检查行动与经过 AG-Proof 验证的请求事实是否一致（EXEC_MISMATCH）。强调授权域的检查是只读的，预算的真正预留仍在网关的接受事务中原子完成。

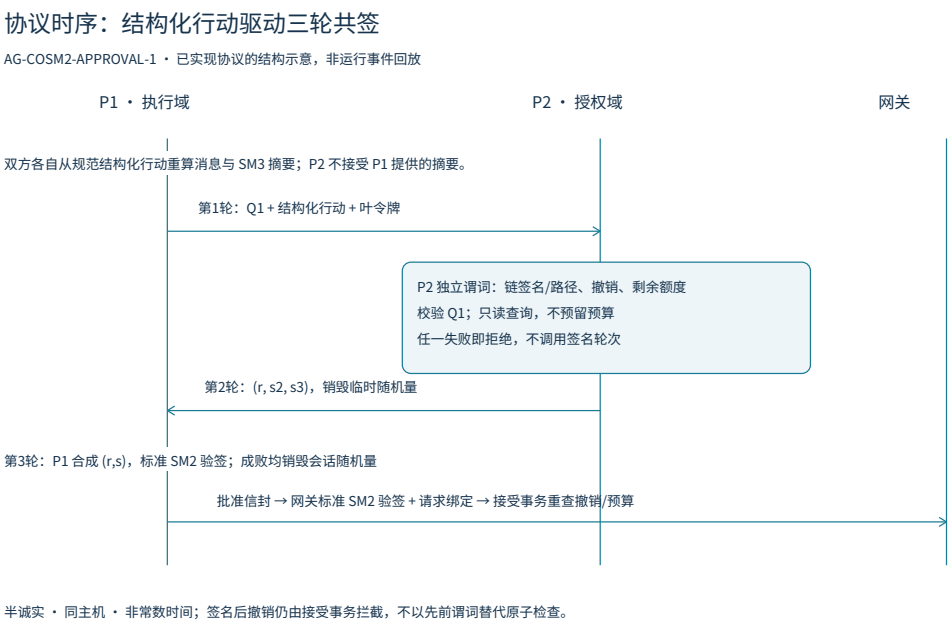


图 2: 谓词门控的两方协同 SM2 签名流程

4.5 与接受事务的组合

写作指引：说明签名不替代原有检查：网关先验 SM2 令牌与 AG-Proof，再验共签签名，并在接受事务内把行动与实际订单、可信报价、授权路径逐项比对，原子写入 action_id 到操作的绑定（不可覆盖），锁后再按数据库时钟检查一次过期。由此得到两层撤销保护：签名前撤销时，授权域拒绝出份额；签名后撤销时，接受事务拒绝。

4.6 推广到 t-of-n 访问结构（设计）

写作指引：这一小节是**设计**，标题和正文都要写明“尚未实现”。要点：（1）推广的目的是可用性，即某个域宕机时仍能签名；（2）为保证撤销不可绕过，授权域必须是必选方，访问结构为“授权域 $\wedge$（其余 $n-1$ 个域中任意 $t-1$ 个）”，而不是简单的 t-of-n；（3）可基于 [8, 9] 中的门限 SM2 构造实现，代价是引入同态加密或零知识证明；（4）可增加审计域，只有在行动写入只追加日志并取得包含证明后才出份额，从而做到“未入账即无法执行”。

5 安全性分析

定义 1 (执行授权不可伪造性)**.** 在假设 1 and 2下，考虑如下游戏：敌手与系统交互，可以请求任意行动的共签。若敌手最终让验签方接受了某个行动 act*，而在所有对 act* 的签名会话中，诚实域的谓词均不成立（或从未有诚实域参与 act* 的会话），则敌手获胜。若任何多项式时间敌手的获胜概率均可忽略，则称方案满足执行授权不可伪造性。

定理 1. 若两方协同签名协议在半诚实模型下安全地实现了 SM2 签名功能，且 SM2 满足 EUF-CMA，则本文方案满足定义 1。

写作指引：证明分两种情况写，每种情况都归约到 SM2 的不可伪造性。

证明思路. 情况一：敌手攻破 P_{E}。由于 P_{A} 只对谓词成立的行动参与签名，并且自行由 act 计算 e，敌手从协议中得到的只是谓词成立行动上的签名。若敌手能为 act* 产生有效签名，可构造一个伪造者 $\mathcal{B}$，利用协议的模拟器把它转化为对 SM2 签名谕言机的伪造。 情况二：敌手攻破 P_{A}。对称地，P_{E} 只对与经过验证的请求事实一致的行动发起会话。【待填：C 补全：引用所采用协议的安全性证明（[6] 或替代文献），说明模拟器如何构造】。 另外，签名之后发生的撤销由接受事务拒绝，这依赖假设 2中验签方可信。 □

写作指引：可选：用 ProVerif 或 Tamarin 对“委托—出份额—撤销—接受”流程建模，验证一条可达性性质（撤销后不存在被接受的新行动）。只有真正跑出结果才写，否则不写。不要写“已形式化证明安全”。

不覆盖的情况。 两域同时被攻破；恶意参与方（需引入零知识证明）；侧信道；拒绝服务（任一域离线即无法签名，t-of-n 推广用于缓解）。

6 实现

写作指引：用表格列出模块、语言、代码位置和行数（行数用 wc -l 实测）。写明依赖版本：tongsuopy 1.0.1（铜锁 8.3.2），PostgreSQL 16，Python 3.11。强调网关验签使用铜锁的标准 SM2 验签，而非自写代码；自写的曲线运算只用于生成份额，并且产生的签名已被 OpenSSL 3 独立验证。

表 2: 实现概况

模块	位置	规模	状态
协同签名核心	`src/agent_guard/cosign/`	【待填：行】	【待填：已实现/测试数】
授权域谓词签名者	`cosign/authz_domain.py`	【待填：行】	【待填：】
网关方案切换	`threshold/verifier.py` 等	【待填：行】	【待填：】
委托授权基础	`authorization/`	【待填：行】	已有
接受事务与预算	`ledger/`、`execution/`	【待填：行】	已有

7 实验评估

写作指引：只报告实际跑出来的结果。每张表、每张图的图注都写清 run_id 或命令、样本数和环境。小样本报告中位数和 p95，不报告“提升百分之多少”。历史证据、本轮真实运行和示意图分开呈现。

7.1 实验环境

【待填：CPU 型号、内存、操作系统、Docker 镜像标签、Python/tongsuopy/PostgreSQL 版本、代码提交号】

7.2 正确性与攻击拒绝

表 3：攻击与拒绝位置（双域共签各行来自固定运行 01af29ac-26be-4616-851d-d8afa38fa46e；“委托扩权”行来自场景 3 运行 【待填：run_id】）

攻击	拒绝位置	拒绝码	新订单数	
盗用令牌（无私钥）	网关（持有者证明）	INVALID_SIGNATURE	0	0
委托扩权（场景 3）	AS	【待填：】	0	0
行动越权（超出令牌范围）	**授权域**	AUTHZ_SCOPE	0	0
撤销后再请求共签	**授权域**	AUTHZ_REVOKED	0	0
共签后撤销	接受事务	REVOKED	0	0
单域伪造签名	网关验签	INVALID_SIGNATURE	0	0
签名后篡改金额	网关（批准与订单比对）	APPROVAL_MISMATCH	0	0
超出剩余预算	**授权域**	AUTHZ_OVER_BUDGET	0	0
绕过网关直接调用下游	下游订单服务	DOWNSTREAM_UNAUTHORIZED	0	0
合法共签（对照）	—	—	1	

写作指引：上表的值是示例结构，必须用真实运行结果逐格替换；没跑过的行删掉。另附一句：产出的签名经 OpenSSL 3 `pkeyutl -verify` 独立验证通过（A1 脚本输出）。

7.3 性能

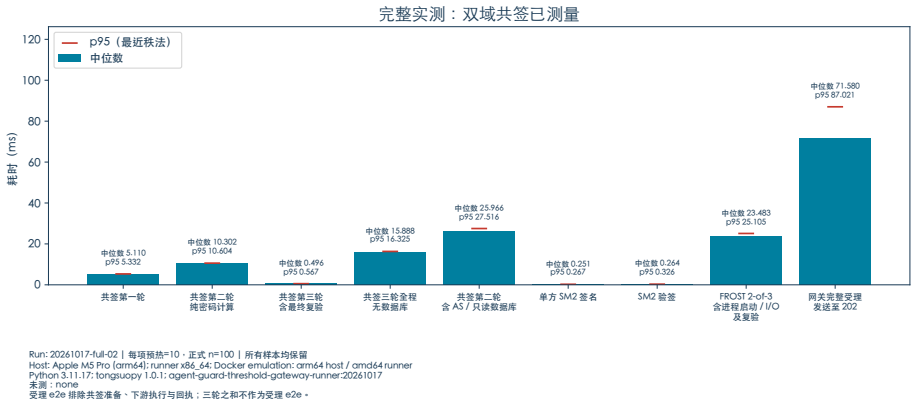


图 3: 协同签名各阶段与对照方案的耗时（$n = 100$，预热 10 次）

写作指引：分析时要说明：纯 Python 标量乘是主要开销，换用常数时间的原生实现可以显著降低；与网关一次受理的总耗时相比，签名开销占比为多少（用实测数字说话）。

7.4 演示

写作指引：放 1–2 张前端截图：双域共签页（真实结果，带 run_id 标签）、撤销场景。图注写明“现场运行”还是“记录回放”。

表 4: 耗时统计（单位：ms）

测量项	样本数	中位数	p95	说明
协同签名（三轮合计，不含谓词）	100	【待填：】	【待填：】	原型，纯 Python
授权域谓词检查	【待填：】	【待填：】	【待填：】	含数据库只读查询
单方 SM2 签名	100	【待填：】	【待填：】	铜锁
SM2 验签	100	【待填：】	【待填：】	铜锁
FROST 2-of-3	100	【待填：】	【待填：】	含子进程启动
网关端到端受理	【待填：】	【待填：】	【待填：】	

8 讨论与局限

写作指引：逐条如实写出：（1）$n = 2$，t-of-n 仅为设计；（2）半诚实模型；（3）演示中两域位于同一主机、同一操作系统用户，授权域使用只读数据库角色【待填：是否真正隔离】；（4）标量乘不是常数时间；（5）网关失陷时，签名之后的撤销在批准有效期内不受保护，下游效果端不复查撤销与预算（后续工作：效果端补充动态状态核验或缩短批准有效期）；（6）x402 部分为本地测试链和测试资产，链上结算签名仍为 EIP-3009；（7）智能体为确定性脚本，未接入真实大模型；（8）规模化实验尚未完成。

9 结论

写作指引：3–4 句：重述“授权即密钥”的主张，已实现了什么、证据是什么，以及下一步（t-of-n、恶意安全、效果端验签、真实大模型代理）。

参考文献

[1] M. Jones, A. Nadalin, B. Campbell, et al. OAuth 2.0 Token Exchange. RFC 8693, 2020.

[2] D. Fett, B. Campbell, J. Bradley, et al. OAuth 2.0 Demonstrating Proof of Possession (DPoP). RFC 9449, 2023.

[3] T. Lodderstedt, J. Bradley, A. Labunets, D. Fett. Best Current Practice for OAuth 2.0 Security. RFC 9700, 2025.

[4] 国家市场监督管理总局, 国家标准化管理委员会. GB/T 32918–2016 信息安全技术 SM2 椭圆曲线公钥密码算法.

[5] GB/T 32905–2016 信息安全技术 SM3 密码杂凑算法.

[6] 尚铭, 马原, 林璟锵, 荆继武. SM2 椭圆曲线门限密码算法. 密码学报, 2014, 1(2): 155–166. 【待填：C 核对卷期页码，并确认其中两方签名结构与本文一致；若不一致，换成实际采用的协议来源】

[7] 【待填：作者】. A SM2 Elliptic Curve Threshold Signature Scheme without a Trusted Center. KSII Transactions on Internet and Information Systems, 2016.

[8] 【待填：作者全名】 Liang, Chen. Non-interactive SM2 threshold signature scheme with identifiable abort. Frontiers of Computer Science, 2024.

[9] 【待填：作者】. Faster threshold-SM2 with identifiable abort and non-interactive online signing. Cybersecurity, 2025.

[10] C. Komlo, I. Goldberg. FROST: Flexible Round-Optimized Schnorr Threshold Signatures. SAC 2020.

[11] D. Connolly, C. Komlo, I. Goldberg, C. A. Wood. The Flexible Round-Optimized Schnorr Threshold (FROST) Protocol for Two-Round Schnorr Signatures. RFC 9591, 2024.

[12] Y. Zheng, Q. Zhang. From Review to Authorization: Key-Isolated Threshold Signing for LLM Agents. arXiv:2609.05901, 2026.

[13] x402 Foundation. x402 Protocol Specification v2. `https://github.com/x402-foundation/x402`, 【待填：固定提交号与查阅日期】.